

Chapter 5 - Security, Privacy, and Trust-Boundary Engineering

1. Document control

Status: Owner-authorized working amendment; recertification pending. Control families: SEC-001 SEC-002 SEC-003 SEC-004 SEC-005 SEC-006 PRV-001 PRV-002. Version: 1.1. Source authority: Book I then Book II.

2. Purpose

This chapter defines enforceable common engineering standards for sdl, threat models, identity, authentication, authority, permission, least privilege, firewall, crypto, classification, privacy, treaties, supply chain, vulnerabilities.

3. Scope

Applies to every HAL contributor, change, component, provider adapter, interface, environment, and release within this subject area.

4. Authority and source requirements

Book I Articles I, II, V, VI, VIII, XI, XII; Decisions 26-27, 32, 36-37, 39, 48-49. Book II 04, 05, 18, 19, 20, 21, 26. If this chapter conflicts with either source, the higher-order requirement governs; record the conflict and correct Book III.

5. Definitions

Conformance evidence is a durable, reviewable record. A consequential change affects authority, identity, protected state, trust, privacy, a Reality Boundary, availability, or a material outcome. A control exception is a time-bounded approval, never a silent permission.

6. Normative standards

Every request crossing a trust boundary MUST carry authenticated identity, bounded Authority, purpose, provenance, and correlation context. Permission MUST be evaluated by the authoritative policy path within current Authority, not inferred from network, role label, secret possession, or provider usefulness. Data collection and disclosure MUST follow a classification, purpose, minimization, retention, and deletion/archival rule.

7. Required engineering practices

Teams MUST perform design, security, privacy, reliability, and verification work in proportion to risk. Teams MUST retain evidence in the change or release record and MUST update traceability when requirements, interfaces, controls, or evidence change.

8. Prohibited practices

Treating trust as authority; cross-domain exchange outside the Constitutional Firewall; long-lived ambient credentials; unapproved Treaty or new capability class; plaintext sensitive data in transit or at rest are prohibited.

9. Required evidence

Threat model, data inventory, access decision log, Treaty record, key-management record, SBOM, vulnerability disposition.

10. Automated enforcement

Threat-model, negative Authority and Permission, firewall, privacy, cryptographic, dependency-provenance, and penetration tests.

11. Human review requirements

Security Authority reviews threats and exceptions; Privacy Authority reviews data use; Owner authority is required only where Book I reserves it.

12. Exceptions and waiver authority

An exception MUST identify affected control, justification, scope, risk, compensating controls, approver, effective date, expiration date, review date, evidence, and revocation conditions. Constitutional invariants cannot be waived. Architecture deviations follow the architecture-governance process. Expiration MUST fail closed or trigger explicit escalation.

13. Failure consequences

A violated MUST control is a finding. Critical or high findings block merge or release until corrected, contained, or covered by an active approved exception. A detected authority, privacy, or trust-boundary failure MUST be contained and investigated.

14. Security considerations

Controls MUST preserve explicit identity, authority, provenance, and least privilege; security controls protect HAL, while authority controls also prevent HAL from exceeding its mandate.

15. Privacy considerations

Evidence and telemetry MUST minimize personal and sensitive data, use classification-aware access, and retain only what is required for the stated purpose and governing obligation.

16. Reliability considerations

Critical behavior MUST define hazard-bounded degradation, containment, recovery, and evidence preservation. Applicable safety invariants, authority controls, and audit standards MUST NOT be degraded under resource pressure.

17. Verification method

Verify through automated checks and risk-scaled test/release evidence, plus independent review or the documented Solo-Owner Assurance Profile where Book III Chapter 8 §11.1 permits it. Critical invariants require an identified repeatable verification method; critical failure modes require tested containment or recovery.

18. Metrics

Track control pass rate, finding severity and age, exception count and age, verification coverage by risk, rollback/recovery performance, and post-release conformance defects.

19. Traceability to Book I

Book I Articles I, II, V, VI, VIII, XI, XII; Decisions 26-27, 32, 36-37, 39, 48-49.

20. Traceability to Book II

Book II 04, 05, 18, 19, 20, 21, 26.

21. Examples

Example: the change record links the control IDs, source locators, test result, and approval before a protected action is released.

22. Anti-patterns

Anti-pattern: a technically successful change is released without authority-path verification because it appears operationally routine.

23. Review findings

Initial constitutional, architecture, enforceability, testability, security, privacy, reliability, usability, automation, exception-safety, duplication, and contradiction review: no unresolved internally resolvable issue. Reassess when implementation evidence is available.

24. Owner Review items

None. Routine implementation choices are resolved through engineering judgment. Escalate only matters reserved by Book I.

25. Completion status

Draft complete; chapter review record required before certification.